

# Halden Distribution Ltd. — IT policy pack

**Version:** v0.1 · **Owner:** IT Lead · **For approval by:** the Managing Director **Issued:** 2026-10-02 · **Review date:** 2027-10-02 (annual, or after a significant change)

**Approval block — deliberately unsigned.**

|                                       |            |            |            |
|---------------------------------------|------------|------------|------------|
| Role                                  | Name       | Signature  | Date       |
| ---                                   | ---        | ---        | ---        |
| Managing Director (approves the pack) | (unsigned) | (unsigned) | (unsigned) |
| IT Lead (owns and maintains the pack) | (unsigned) | (unsigned) | (unsigned) |

Halden Distribution Ltd. is a **fictional** 85-user company used for a home-lab portfolio. These policies are written to be realistic and adoptable by a small company, but no real organisation has approved them. `data/policy-register.csv` records the approval state and it is empty on purpose.

## How to use this pack

Ten short policies, each 1–2 pages, plain English, each with a purpose, scope, statements, roles, an exceptions route, an owner, a version and a review date. A policy that nobody reads protects nobody, so these are deliberately short. Staff acknowledge the Acceptable Use Policy; new starters receive it in their welcome pack (P2). Everyone else is *informed* of the rest.

**Exceptions:** any exception is recorded in one register with an owner and an expiry date (see the bottom of this document). An exception with no expiry is not an exception, it is an undocumented change.

## 1. Information Security Policy (umbrella)

**Purpose:** state management's commitment to protecting Halden's information and set the framework the other nine policies sit inside. **Scope:** all staff, contractors, systems and data. **Statements:**

1. Information is an asset; it is protected in proportion to its sensitivity and to the risk to the business if it were lost, altered or disclosed.
1. The Managing Director is accountable for information security; the IT Lead is responsible for implementing this pack and reporting on it monthly.
1. Halden maintains an information security baseline based on **\*\*CIS Controls v8.1 Implementation Group 1\*\***, reviewed quarterly, with a scorecard reported to management.
1. Control is measured, not assumed: a safeguard is only counted as implemented when there is evidence, and the assessment tool refuses a "fully implemented" score with no evidence.
1. Legal, contractual and insurance obligations are met, including the cyber-insurance renewal questionnaire. **Roles:** Managing Director (accountable) · IT Lead (responsible) · all staff (follow the policies). **Review:** annually, or after any significant change or incident.

## 2. Acceptable Use Policy (staff-facing)

---

**Purpose:** tell staff, in plain language, what is and is not acceptable use of Halden's IT. **Scope:** everyone using Halden devices, accounts, networks or data, including remote work. **Statements:**

1. Halden devices and accounts are for work. Limited personal use is tolerated if it is lawful, does not affect performance and creates no risk.

1. **Passwords are personal and never shared**, written down in plain sight, or reused across services. Multi-factor authentication is required where it is offered.

1. **Report anything suspicious immediately** (see policy 8). Nobody is in trouble for reporting a mistake promptly; they are in trouble for hiding one.

1. Company data stays in company systems. **\*\*Do not paste company data into public AI tools, personal**

cloud storage or unapproved apps\*\* — shadow IT is a real problem at Halden and this is the rule that addresses it. Approved AI tooling is listed in the IT service catalogue (P9).

1. Do not install unapproved software on Halden devices. Requests go to the service desk; approved software is added to the software catalogue.

1. Lock your screen when you leave your desk (10-minute automatic lock is enforced, policy 5).

2. Lost or stolen devices must be reported to IT the same day so it can be remotely wiped.

**Roles:** all staff (comply and acknowledge) · IT Lead (maintains the list of approved tools).

**Acknowledgement:** all staff read and acknowledge this policy; the acknowledgement rate is a reported number ( `data/policy-register.csv` ).

## 3. Access Control and Identity Standard

---

**Purpose:** ensure people can access what their role needs — and nothing more — and lose it the moment their role changes. **Scope:** all user accounts and access to Halden systems and file shares.

**Statements:**

1. Access is requested by the line manager and approved by the **department head**, never by IT alone. IT implements what the business approves.

1. Access is granted by **role group**, using the least-privilege model (accounts → role groups → resource groups → permission). A user is never placed directly on a folder permission (P1).

1. Every joiner, mover and leaver is processed through the automated lifecycle process (P2) from the HR record, so changes are consistent and logged.

1. **Leavers are disabled immediately** on their last working day, and the account is moved to the disabled holding area rather than deleted, to preserve the audit trail (P2).

1. Access is reviewed at least quarterly with the department heads, and dormant accounts are disabled after 45 days of inactivity (P2, and CIS IG1 safeguard 5.3).

1. Multi-factor authentication is required for remote access, administrative access and externally

exposed applications (P2, P6). **Roles:** department heads (approve, review) · IT Lead (implement, report) · HR (trigger the lifecycle event).

## 4. Privileged Access Standard

---

**Purpose:** stop everyday accounts from being able to break the company. **Scope:** administrative accounts, service accounts and the systems they touch. **Statements:**

1. Administrative rights are held only by **dedicated administrator accounts**. Day-to-day work — email, browsing, Office — is done from a standard account (CIS IG1 safeguard 5.4).

1. Access is tiered (Tier 0 for identity systems, Tier 1 for servers, Tier 2 for workstations) and privileged accounts are named and recorded (P3).

1. Local administrator passwords are managed by **Windows LAPS**, are unique per device and rotate automatically; a standard user is denied access to them (P3).

1. Service accounts have a named owner, a documented purpose and a review date (CIS IG1 safeguard 5.5).

1. A break-glass procedure exists for emergencies, is tested on a schedule, and its use is reviewed and logged.

1. Administrative access requires MFA where supported (CIS IG1 safeguard 6.5).

**Roles:** IT Lead (owns privileged access) · Managing Director (approves a new Tier 0 admin).

## 5. Endpoint Security Standard

---

**Purpose:** make every laptop and desktop a hard target and a known state. **Scope:** all Windows and Linux endpoints owned or used by Halden. **Statements:**

1. Endpoints are built from a documented secure baseline derived from the Microsoft security baseline and applied by Group Policy (P4). The baseline is version-controlled (P9).

1. Disk encryption (**BitLocker**) is enabled on all end-user devices, and recovery keys are escrowed and tested (CIS IG1 safeguard 3.6).

1. Microsoft Defender is enabled with automatic signature updates, and attack-surface reduction rules are applied after an audit period (P4).

1. Autorun and autoplay for removable media are disabled (CIS IG1 safeguard 10.3).

2. Only supported operating systems and browsers are permitted. Unsupported software is either removed or recorded with an exception and a residual-risk acceptance (CIS IG1 safeguard 2.2).

1. Endpoint compliance is reported monthly; the target is  $\geq 95\%$  compliant.

**Roles:** IT Lead (builds and monitors the baseline) · all staff (keep devices powered on for patching, report problems).

## 6. Patch and Vulnerability Management Policy

---

**Purpose:** keep the window between a vulnerability being known and being fixed as short as the business can tolerate. **Scope:** all servers, workstations, network devices and applications. **Statements:**

1. Operating system and application patching is automated on a monthly or more frequent cycle, using

update rings (a pilot ring first, then broad deployment) (P5).

1. Vulnerabilities are prioritised by **risk**, not by score alone: known-exploited status, exposure, whether an exploit is automatable, and the criticality of the asset (P5).

1. Remediation deadlines follow the risk tier; the highest tier is acted on within days (P5).

2. Internal vulnerability scans run at least quarterly; the results feed the prioritisation engine and the monthly KPI report.

1. Any accepted vulnerability is recorded with a business owner, a reason and an expiry date.

**Roles:** IT Lead (owns the process and the dashboard) · asset owners (support remediation windows).

## 7. Network and Remote Access Standard

---

**Purpose:** stop the flat network being a single door to everything. **Scope:** the firewall, VLANs, Wi-Fi, the VPN and any remote connection. **Statements:**

1. The network is segmented into zones (servers, users, management, guest, IoT) with traffic filtered between them by default-deny firewall rules; the rule set is documented in a matrix and reviewed when it changes (P6).

1. **Remote access is through an MFA-protected VPN;** direct exposure of management protocols such as

RDP to the internet is prohibited (P6).

1. Wi-Fi uses WPA2/WPA3-Enterprise with 802.1X authenticated against the directory (P6).
2. Guest and IoT devices receive internet only, and are isolated from business systems (P6).
3. Network devices are kept up to date and support status is verified at least monthly (CIS IG1

safeguard 12.1).

1. DNS filtering is applied to block known-malicious domains (CIS IG1 safeguard 9.2).

**Roles:** IT Lead (owns the rule set) · all staff (use the VPN for remote work).

## 8. Logging, Monitoring and Incident Response Policy

---

**Purpose:** see an attack, and respond to it in a way that is rehearsed rather than improvised. **Scope:** all servers, endpoints, network devices and services. **Statements:**

1. Security-relevant events are collected centrally into the SIEM, and detailed audit logging is enabled on assets holding sensitive data (P7).

1. Logs are retained for at least 90 days (CIS IG1 safeguard 8.10).

2. Alerts are triaged and reviewed weekly; high-severity alerts are investigated promptly (P7).

3. **Anyone can and must report a suspected incident** — to the service desk, or directly to the IT Lead. Reports are welcomed, not punished. The reporting route is published to all staff.

1. Named incident roles exist, with at least one deputy; a contact list (internal, vendors, insurer, authorities) is verified annually (P7).

1. Incident-response playbooks exist for the main scenarios and are exercised; lessons learned become

actions in the tracker and, where needed, changes to this pack. **Roles:** IT Lead (incident handling) · senior manager (deputy/decision maker) · all staff (report).

## 9. Backup and Recovery Policy

---

**Purpose:** guarantee the business can get its data back. **Scope:** all systems and data in the recovery scope defined in the business impact analysis. **Statements:**

1. Backups follow the **3-2-1-1-0** rule: three copies, two media, one off-site, one immutable or offline, and zero errors on verified restore (P8).

1. Backups run automatically at least weekly, and more frequently for high-sensitivity data.

2. **Restores are tested** on a schedule — files are compared by hash and a virtual machine is booted into an isolated sandbox. A backup that has not been restored is not a backup.

1. Recovery data is encrypted and protected to the same standard as the original, and at least one copy is isolated so ransomware cannot reach it (CIS IG1 safeguards 11.3, 11.4).

1. Recovery time and recovery point targets are agreed with the business in the BIA and tested by a timed drill; the measured result is reported, never assumed.

1. The backup repository is not a member of the domain, so that a domain compromise does not hand an

attacker the backups. **Roles:** IT Lead (runs and tests backups) · department heads (agree priorities and targets in the BIA).

## 10. Change and Asset Management Policy

---

**Purpose:** make sure the business knows what it has, and that nothing changes without someone knowing why. **Scope:** all changes to services, systems and configurations, and all IT assets.

**Statements:**

1. Every IT asset is inventoried in the CMDB with an owner, a location and a lifecycle status; unauthorised assets are removed or quarantined weekly (P9, CIS IG1 safeguards 1.1, 1.2).

1. Changes are classified **standard**, **normal** or **emergency**, and follow the process in

`docs/runbooks/raise-and-approve-a-change.md` :

- standard changes are pre-approved in a catalogue;
  - normal changes go to the weekly CAB with a risk assessment;

- emergency changes are approved by ECAB and reviewed retrospectively within two business days.

- **No change is approved without a rollback plan**, and risky changes require a tested rollback or a snapshot.

1. Change freeze periods are agreed with the departments (month-end for Finance, peak dispatch season

for Operations).

1. Configuration is stored as code and version-controlled; a configuration change with **\*\*no matching approved change record** is treated as an **unauthorised change\*\*** and investigated (P9).

1. Change performance (success rate, emergency share, unauthorised changes) is reported monthly.

**Roles:** CAB (approves normal changes) · IT Lead (runs the process) · all staff (raise changes rather than making them quietly).

---

## Exceptions register

| ID      | Policy | Exception | Reason | Owner | Approved by | Expiry |
|---------|--------|-----------|--------|-------|-------------|--------|
| (empty) |        |           |        |       |             |        |

An exception must have a business owner and an expiry date. Until the register has a real entry, it stays empty — the P10 tooling reports the count as zero rather than inventing an example.

## Acknowledgement

| Policy                  | Audience  | Acknowledgement method                             | Rate                                               |
|-------------------------|-----------|----------------------------------------------------|----------------------------------------------------|
| 2 Acceptable Use Policy | all staff | service desk form / Microsoft Form                 | <b>not measured</b> — no staff have been asked yet |
| The remaining nine      | informed  | published in the documentation hub (BookStack, P9) | n/a                                                |

## Version history

| Version | Date       | Author  | Change                                                             |
|---------|------------|---------|--------------------------------------------------------------------|
| v0.1    | 2026-10-02 | IT Lead | First draft of the ten-policy pack for approval. Not yet approved. |